

Marco integrativo GQM + PRAGMATIC para indicadores CAASM

1. Introducción

Este documento integra la metodología Goal–Question–Metric (GQM) con la evaluación PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable) aplicada a los indicadores propuestos para un marco nacional CAASM.

Se parte de los grandes objetivos nacionales (nivel país) en materia de ciberseguridad y gestión de la superficie de ataque, se descomponen en preguntas GQM y se vinculan con métricas técnicas, cada una evaluada bajo los nueve criterios PRAGMATIC.

2. Objetivos GQM de alto nivel (nivel nacional)

- G1. Asegurar una **alta visibilidad** de la superficie de ataque de activos críticos (TI, OT, IoT, nube, identidades, APIs) en organizaciones esenciales e importantes.
- G2. Reducir la **exposición material** a amenazas relevantes, priorizando en función de impacto de negocio y probabilidad de explotación.
- G3. Mejorar la **capacidad de remediación y respuesta**, reduciendo tiempos de mitigación de exposiciones críticas y altas.
- G4. Demostrar y sostener el **cumplimiento regulatorio** (NIS2, ENS, GDPR, DORA, etc.) mediante evidencias continuas.
- G5. Fortalecer la **gobernanza y la cooperación** público–privada en la gestión de la superficie de ataque.

3. Cadenas GQM por objetivo

3.1. G1 – Visibilidad

Goal (G1)

Garantizar que el inventario de activos críticos de las entidades esenciales e importantes es completo, actualizado y útil para gestionar la superficie de ataque.

Questions (ejemplos)

- Q1.1: ¿En qué medida los activos críticos están registrados en plataformas CAASM u homólogas?
- Q1.2: ¿Qué proporción de activos descubiertos permanece fuera de inventarios formales (shadow IT)?
- Q1.3: ¿Qué cobertura existe por dominios (TI, OT, nube, APIs, identidades)?

Metrics (ejemplos)

- M1.1: Porcentaje de activos críticos descubiertos vs estimados.
- M1.2: Ratio de activos “no inventariados” detectados por CAASM.
- M1.3: Porcentaje de dominios tecnológicos cubiertos por al menos una fuente de inventario integrada.

3.2. G2 – Exposición y riesgo

Goal (G2)

Reducir de forma medible la exposición a amenazas relevantes, priorizando por impacto de negocio y probabilidad de explotación.

Questions

- Q2.1: ¿Cuántos servicios críticos están expuestos a Internet sin controles mínimos?
- Q2.2: ¿Qué porcentaje de exposiciones con alta probabilidad de explotación permanece abierto más allá de los plazos objetivos?
- Q2.3: ¿Dónde se concentran las combinaciones “tóxicas” de criticidad, exposición y vulnerabilidades?

Metrics

- M2.1: Número y proporción de servicios expuestos sin controles mínimos.
- M2.2: Porcentaje de vulnerabilidades/exposiciones con alta probabilidad de explotación pendientes de mitigación.
- M2.3: Número de activos con combinaciones tóxicas (alta criticidad + exposición + vulnerabilidades graves).

3.3. G3 – Remediación

Goal (G3)

Reducir los tiempos de mitigación y aumentar la tasa de cierre de exposiciones críticas dentro de los plazos definidos.

Questions

- Q3.1: ¿Cuál es el tiempo medio de mitigación de exposiciones críticas y altas?
- Q3.2: ¿Qué porcentaje de exposiciones críticas se resuelven dentro de los SLA?
- Q3.3: ¿Qué nivel de automatización existe en los flujos de remediación?

Metrics

- M3.1: MTTR de exposiciones críticas (días).
- M3.2: % de exposiciones críticas cerradas en plazo.
- M3.3: % de remediaciones realizadas mediante flujos automatizados.

3.4. G4 – Cumplimiento

Goal (G4)

Demostrar cumplimiento sostenido mediante evidencias continuas derivadas de CAASM.

Questions

- Q4.1: ¿Qué porcentaje de controles ENS/NIS2 dispone de evidencias automáticas?
- Q4.2: ¿Qué brecha existe entre exposiciones identificadas y no conformidades detectadas en auditorías?

Metrics

- M4.1: % de controles ENS/NIS2 con evidencia automática.
- M4.2: N° de no conformidades que ya habían sido señaladas por CAASM/ASM.

3.5. G5 – Gobernanza y cooperación

Goal (G5)

Integrar CAASM en la gobernanza nacional y la cooperación público-privada.

Questions

- Q5.1: ¿Qué porcentaje de entidades esenciales comparte métricas de superficie de ataque con CSIRTs y autoridades?
- Q5.2: ¿Existe un repositorio nacional de patrones de exposición recurrentes?

Metrics

- M5.1: % de entidades que comparten telemetría de superficie de ataque.
- M5.2: N° de patrones de exposición documentados y reutilizados a nivel nacional.

4. Inserción de PRAGMATIC en el ciclo GQM

Para cada métrica identificada en las cadenas GQM se evalúa su calidad con los criterios PRAGMATIC:

- P – Predictivo: ¿Anticipa cambios futuros relevantes?
- R – Relevante: ¿Está alineada con el objetivo (Goal) que pretende servir?
- A – Accionable: ¿Conduce a decisiones claras o cambios concretos?
- G – Genuino: ¿Refleja fielmente la realidad, sin artefactos o distorsiones?
- M – Significativo (Meaningful): ¿Es comprensible y valiosa para sus audiencias?
- P – Preciso: ¿Está definida de forma inequívoca, repetible y consistente?
- T – Oportuno (Timely): ¿Está disponible con la frecuencia y latencia adecuadas?
- I – Independiente: ¿No está excesivamente sesgada por incentivos o manipulable?
- C – Rentable (Cost-effective): ¿Es coste-efectivo obtenerla y mantenerla?

Cada métrica se puntúa, por ejemplo, en una escala de 1 (bajo) a 5 (alto) para cada criterio. Estas puntuaciones se pueden consolidar para seleccionar y priorizar las métricas más sólidas.

5. Ejemplo de aplicación integrada

Tomemos M2.2: “Porcentaje de vulnerabilidades/exposiciones con alta probabilidad de explotación pendientes de mitigación”.

- G2: reducir exposición material a amenazas relevantes.
- Q2.2: ¿Qué porcentaje de esas exposiciones permanece abierto más allá de lo deseable?
- M2.2: medido trimestralmente, por sector.

Evaluación PRAGMATIC resumida:

- Predictivo: alto (una tendencia al alza anticipa incidentes graves).
- Relevante: máximo (está en el corazón del objetivo G2).
- Accionable: alto (lleva a reforzar recursos, procesos y priorización).
- Genuino: medio–alto (depende de calidad de inventario y de modelos de probabilidad).
- Significativo: alto (fácil de explicar a dirección).
- Preciso: medio–alto (requiere definiciones claras de “alto riesgo” y “mitigado”).
- Oportuno: variable, según capacidad de actualización.
- Independiente: medio (puede verse afectada por incentivos de reporting).
- Rentable: razonable, si se apoya en herramientas ya desplegadas.

Este tipo de análisis permite descartar métricas “bonitas” pero poco útiles, y concentrar la capacidad institucional en aquellas que realmente sirven al propósito nacional.

Fin del documento.